



Government
Digital Service



Department for
Science, Innovation
& Technology

Aligning an AWS Web Application Firewall (WAF) implementation strategy with Secure by Design

November 2025

OFFICIAL
L

Contents

Background	3
Purpose	3
Secure by Design on the UK Government Security website	3
1. Architectural overview	4
2. Design considerations	4
3. Policy and rule framework	5
4. Integration with AWS services	5
5. Operations and management	6
6. Governance and compliance	6
7. Continuous improvement	7
More information	7

Background

[AWS Web Application Firewall \(WAF\)](#) is a cloud-based security solution designed to protect web applications from common threats like:

- SQL injection
- cross-site scripting (XSS)
- distributed denial-of-service (DDoS) attacks

It lets users define custom rules to filter and block malicious traffic while monitoring web requests in real time.

The [Secure by Design](#) approach is a government framework which embeds cyber security into digital services from the outset. Its goal is to make security an integral, proactive part of all government digital systems, rather than an afterthought.

Purpose

The purpose of this document is:

- to act as a reference guide for implementing AWS WAF
- to align AWS WAF with the government's Secure by Design principles
- to outline design considerations, policy and rule framework, operations, governance and continuous improvement of the AWS WAF solution

Secure by Design on the UK Government Security website

- [Secure by Design policy](#)
- [Implementing Secure by Design](#)
- [Guide to adopting Secure by Design](#)

1. Architectural overview

A robust AWS WAF architecture mitigates threats effectively by using flexible layers of protection. You can adjust modular web access control lists (ACLs) and rule groups as business requirements evolve, and doing so aligns with Secure by Design principle 10, [Make changes securely](#).

AWS WAF should form part of a multi-layered security design, in combination with tools such as:

- [Amazon GuardDuty](#)
- [Amazon Route 53 Resolver DNS Firewall](#)
- [AWS Shield Advanced](#)

Multi-layered controls help you satisfy principle 8, [Defend in depth](#).

You should enable centralised management through [AWS Firewall Manager](#) so that rules are enforced consistently. The architecture should be scalable and adapt to changes in traffic and evolving threat landscapes.

Modular and decoupled components let teams integrate new managed rules or threat intelligence feeds without much disruption. This supports principle 6, [Design flexible architectures](#) and aligns with the activity [Managing observability](#).

Integrating the architecture with identity and access management (IAM) policies and role-based access controls also means that only authorised users can modify WAF configurations. This reduces the risk of mistakes or malicious changes, supporting principle 7, [Minimise the attack surface](#) and principle 10, [Make changes securely](#).

2. Design considerations

When you deploy AWS WAF you should think carefully about how exposed your applications are and the risk appetite of your organisation.

Edge deployments on [Amazon CloudFront](#) let you inspect traffic before it reaches origin servers. This reduces the attack surface (which supports Secure by Design principle 7, [Minimise the attack surface](#)) and makes compromise more difficult. Regional WAFs on Application Load Balancers (ALBs) or API gateways provide additional protection for internal or latency-sensitive applications.

Establishing a phased deployment strategy allows teams to validate rules in count mode before full enforcement.

This approach:

- reduces the likelihood of blocking legitimate traffic
- supports operational usability (aligning with principle 5, [Design usable security controls](#))
- enables iterative improvement while [embedding continuous assurance](#) (principle 9)

Once AWS WAF has been deployed, security engineers should focus on custom rule development. They can build precision policies tailored to the behaviour of applications using:

- string matching
- regular expression (regex) filtering
- geolocation conditions
- rate-based thresholds

These bespoke controls should be tested in staging environments using synthetic attack traffic to make sure they're robust and their performance is stable. All rules should be maintained within Infrastructure as Code (IaC) repositories such as [AWS CodeCommit](#) or [GitHub Enterprise](#). Following this process meets Secure by Design principle 10, [Make changes securely](#).

Comprehensive monitoring is essential. You should configure [Metrics in AWS CloudWatch](#) and [CloudWatch Logs](#) to track request counts, blocked attempts and anomaly detection.

[Amazon Data Firehose](#) pipelines can deliver detailed logs to [Amazon S3](#) for long-term storage and forensic review. Security engineers should integrate alerts with [Amazon Simple Notification Service \(SNS\)](#) for rapid incident response. This aligns with Secure by Design principle 5, [Build in detect and respond security](#).

Beyond the initial setup, you should configure AWS WAF to incorporate automation and self-healing mechanisms. [AWS Lambda](#) can dynamically update rule sets or IP reputation lists when suspicious behaviour is detected, which aligns with Secure by Design principle 9, [Embed continuous assurance](#). Automated validation scripts should check for policy drift, so that deployed configurations match approved baselines.

3. Policy and rule framework

A layered policy framework makes security controls practical, maintainable and effective. Baseline protections, including [AWS Managed Rules](#), provide coverage for common vulnerabilities, while custom rules address application-specific behaviours. Rate-limiting, IP reputation filtering and geolocation-based rules reduce exposure while maintaining usability, supporting Secure by Design principle 4 [Design usable security controls](#).

For full accountability and continuous assurance, all rule changes should be:

- version-controlled
- documented
- periodically reviewed

This supports principle 9, [Embed continuous assurance](#). By combining automated evaluation and human oversight, you can validate that rules are aligned with risk priorities.

Additionally, you can keep things clear by standardising the way you name and categorise rules. This makes it simpler when rules are updated or audited.

4. Integration with AWS services

AWS WAF should be integrated with the tools such as:

- Amazon Data Firehose
- AWS CloudWatch
- AWS Firewall Manager
- [AWS Security Hub](#)
- [AWS Shield](#)

This integration supports the following Secure by Design principles:

- [2. Source secure technology products](#) - by using secure, maintained components
- [5. Build in detect and respond security](#) and [9. Embed continuous assurance](#) - by using centralised logging and metrics to provide visibility
- [6. Design flexible architectures](#) - by supporting flexible architectures that can evolve as business requirements change

Integrating these metrics with automated dashboards and alerting helps teams to respond to anomalies quickly. By carrying out proactive analysis and incident correlation, you'll embed detect-and-respond capabilities into routine operations (principle 5, Build in detect and respond security) while making sure there's accountability and ownership of cyber security risk (principle 1, [Create responsibility for cyber security risk](#)).

Importantly, integration with AWS Security Hub and Security Information and Event Management (SIEM) tools lets you correlate WAF events with other security telemetry. This enhances threat detection and response across the environment and supports the following principles:

- 5. Build in detect and respond security
- 9. Embed continuous assurance

5. Operations and management

Once AWS WAF has been deployed, security and platform teams must treat it as a living control that adapts to changing business and threat conditions. Routine activities should include:

- reviewing logs for attack trends
- evaluating false-positive ratios
- tuning rules based on verified incidents

This cyclical refinement aligns with Secure by Design principle 9, [Embed continuous assurance](#) and means controls are effective throughout the service life cycle.

Managing AWS WAF after it's been deployed requires strong governance. You must restrict administrators' access using role-based access controls (RBAC) in [AWS Identity and Access Management \(IAM\)](#). You should put in place peer reviews and dual-control approvals for any rule changes intended for production.

Integrating AWS WAF with monitoring and response ecosystems makes operations more efficient. AWS WAF metrics should feed into AWS Security Hub, [Amazon OpenSearch Service](#) or [Splunk](#) for centralised visibility.

Correlating WAF logs with GuardDuty and [VPC Flow Logs](#) supports Secure by Design principle 8, [Defend in depth](#), by revealing multi-vector attacks spanning network and application layers. Continuous visibility helps teams to detect incidents quickly and contextualise them effectively.

In line with principle 6, [Design flexible architectures](#), operational teams should plan for scalability and resilience. As workloads get bigger, AWS Firewall Manager can apply uniform rules across multiple accounts and Regions, reducing management overhead. And by scheduling policy reviews based on organisational standards, you can make sure that [AWS Managed Rules rule groups](#) are updated and that deprecated rules are retired.

6. Governance and compliance

Governance must define who is responsible for AWS WAF configuration, policy review and incident escalation. By assigning clear ownership, you'll meet Secure by Design principle 1, [Create responsibility for cyber-security risk](#).

Formal policies should describe:

- configuration baselines
- change control processes
- approval routes for exceptions

All changes must be traceable through CloudTrail logs, which provide immutable evidence for compliance reporting. Integrating with [AWS Config Rules](#) lets you continuously assess compliance and be alerted if resources move away from approved standards.

For large government organisations, AWS Firewall Manager can enforce central governance across multiple accounts. This keeps policy application consistent and improves audit readiness.

Regular governance meetings should review metrics such as blocked attack volumes, false-positive trends and patch compliance. Aligning these reviews with wider risk management cycles keeps governance outcome-oriented and supports Secure by Design principle 3, [Adopt a risk-driven approach](#).

Regularly auditing configuration baselines and event logs helps you stay compliant over the long-term and gives you evidence to show regulators and stakeholders.

7. Continuous improvement

Continuous improvement should be central to the AWS WAF life cycle, so that protection stays effective as new threats emerge. Teams must monitor new vulnerabilities, zero-day exploits and attack campaigns, and update rule groups accordingly.

Integrating AWS WAF logs with threat-intelligence feeds helps you detect new indicators of compromise (IoCs) and helps you quickly adapt to changing threat landscapes. By aligning defensive effort with the highest-priority risks, this iterative approach reflects Secure by Design principle 3, [Adopt a risk-driven approach](#).

Automation is a key part of effective continuous improvement. You can automate the testing, approval and rollout of rule changes using [AWS CodePipeline](#) or [AWS Cloud Development Kit \(CDK\)](#). Automated regression testing means that new rules do not block legitimate traffic by accident.

By keeping things usable while improving protection, you'll align with principle 4, [Design usable security controls](#). Having consistent deployment pipelines in place also reduces human error and accelerates your organisation's response to new threats.

You should feed insights from post-incident reviews and quarterly improvement cycles back into configuration baselines so that your organisation is continuously learning. Apply lessons learned from red-team exercises, penetration testing and external audits so that you can refine WAF rules and operational runbooks. This structured evolution of controls supports Secure by Design principle 9, [Embed continuous assurance](#).

More information

- [Secure by Design principles \(UK Government Security\)](#)
- [Secure by Design activities \(UK Government Security\)](#)